CCST Cybersecurity Complete Study Course

Cisco Certified Support Technician: all 5 domains and 22 objectives, explained in plain English with practice questions and answer keys.

Domain	Objectives
1. Essential Security Principles	1.1 – 1.4
2. Basic Network Security Concepts	2.1 – 2.5
3. Endpoint Security Concepts	3.1 – 3.6
4. Vulnerability Assessment and Risk Management	4.1 – 4.4
5. Incident Handling	5.1 – 5.4

How to use this course: each objective has a **Plain-English idea**, a **Deep dive** with the details the exam expects, and **Check yourself** questions. Try the questions first, then compare with the answer key at the end of each domain. Use the PDF bookmarks panel to jump between sections.

This is an unofficial study aid built from the published CCST Cybersecurity exam objectives. Always confirm the current exam details on Cisco's official page.

Master Reference List

Use these all course long. Deep links to individual videos are not included because they could not be verified; search the channel names instead.

Type	Resource	Why it helps
Official course	Cisco Networking Academy, Junior Cybersecurity Analyst / CCST Cybersecurity (skillsforall.com, netacad.com)	Built for this exam
Official exam page	Cisco's CCST Cybersecurity page (search "Cisco CCST Cybersecurity exam")	Objectives and practice information
Videos	Professor Messer (YouTube, professormesser.com)	Free, concise security videos
Videos	NetworkChuck, Cisco Networking Academy (YouTube)	Friendly, beginner-focused
Articles	Cloudflare Learning Center (cloudflare.com/learning)	Clear explanations of DDoS, DNS, TLS, VPN, firewalls
Standards	NIST (csrc.nist.gov), including SP 800-61	Incident response, definitions
Frameworks	MITRE ATT&CK (attack.mitre.org)	Domain 5.2
Vulnerabilities	CVE (cve.org), NVD (nvd.nist.gov)	Domain 4
Government	CISA (cisa.gov)	Alerts, advisories, free guides
Tools	Wireshark (wireshark.org), Nmap (nmap.org)	Hands-on practice
Practice	Cisco Packet Tracer (free via Networking Academy), TryHackMe, VirtualBox	Hands-on labs

DOMAIN 1: Essential Security Principles

1.1 Define essential security principles

PLAIN-ENGLISH IDEA

Security is about protecting valuable things from people or events that could harm them. Before you can defend anything, you need the vocabulary.

DEEP DIVE

The four risk words (the exam loves these):

Term	Meaning	Example
Vulnerability	A weakness	An unpatched server
Threat	Something that *could* exploit a weakness	A hacker, malware, a flood
Exploit	The actual method or code that takes advantage of a vulnerability	A script that abuses the unpatched bug
Risk	The likelihood × impact of a threat exploiting a vulnerability	A high chance of data theft

> Memory trick: a **vulnerability** is an unlocked door. A **threat** is a burglar. An **exploit** is the act of opening the door. **Risk** is how likely and how bad the break-in would be.

Attack vector: the *path* an attacker uses to reach the target, for example email (phishing), USB drives, open ports, web apps, or an unsecured Wi-Fi network.

Hardening: reducing a system's attack surface. Examples: disable unused services, close unneeded ports, remove default accounts, change default passwords, and apply patches.

Defense-in-depth: using **multiple layers** of security so that one failure doesn't mean total compromise. Think of a castle with a moat, walls, guards, and a locked vault. In IT, the layers are physical security, network (firewall), endpoint (antivirus), application, data (encryption), and people (training).

The CIA Triad (the core model of security):

- **Confidentiality:** only authorized people can see the data. Tools: encryption, access controls.
- **Integrity:** data is accurate and has not been altered. Tools: hashing, digital signatures.
- **Availability:** systems and data are accessible when needed. Tools: backups, redundancy, DoS protection.

Types of attackers:

Type	Description
Script kiddie	Low skill, uses premade tools
Hacktivist	Motivated by a cause or political message
Cybercriminal	Motivated by money (ransomware, fraud)
Insider	Employee or contractor with legitimate access
Nation-state / APT	Well-funded, patient, targets governments or critical infrastructure
White hat	Ethical hacker, authorized
Black hat	Malicious

Type	Description
Gray hat	Between the two: no permission, but not (always) malicious

Reasons for attacks: financial gain, espionage, political or social causes (hacktivism), revenge, disruption or sabotage, and curiosity or fame.

Code of ethics: security professionals act legally and honestly, protect confidentiality, get **written authorization** before testing, report findings responsibly, and avoid harming others. Scanning or hacking a system **without permission is illegal**, even if you "mean well."

CHECK YOURSELF

1. An unpatched web server is best described as a: A) threat B) vulnerability C) exploit D) risk
2. A script that takes advantage of that flaw is a(n) _____.
3. A hospital's patient records are altered by an attacker. Which CIA element was violated?
4. Why is defense-in-depth better than one very strong firewall?
5. A hacker finds a bug, tells the company privately, and has written permission to test. What type of hacker is this?

1.2 Explain common threats and vulnerabilities

PLAIN-ENGLISH IDEA

Attackers have a toolbox. You need to recognize each tool by name.

DEEP DIVE

Malware (malicious software):

Type	Key trait
Virus	Attaches to a file and needs user action to spread
Worm	Spreads **by itself** across networks
Trojan	Looks legitimate but hides malicious function
Ransomware	Encrypts files and demands payment
Spyware	Secretly gathers information
Keylogger	Records keystrokes
Rootkit	Hides deep in the OS and conceals itself and other malware
Adware	Unwanted ads, sometimes tracking
Botnet	A network of infected machines ("bots" or "zombies") controlled by a C2 server
Logic bomb	Triggers on a condition (a date, an event)

Denial of Service (DoS): overwhelms a system so legitimate users can't use it (an **availability** attack). **DDoS** does this from many sources at once, usually a botnet.

Social engineering (hacking people, not computers):

- **Phishing:** mass fake emails
- **Spear phishing:** targeted at a specific person or group, using personal details
- **Whaling:** targets executives
- **Vishing:** voice (phone) phishing
- **Smishing:** SMS (text) phishing

- **Pretexting:** an invented scenario ("I'm from IT support...")
- **Baiting:** a tempting lure, such as a USB drive labeled "Salaries"
- **Tailgating / piggybacking:** following an authorized person through a secured door

Physical attacks: theft of devices, dumpster diving, shoulder surfing, rogue USB devices, and cloned access cards.

Man-in-the-Middle (MitM): the attacker secretly sits between two parties, reading or altering their traffic. Examples include evil twin Wi-Fi, ARP spoofing, and session hijacking.

IoT vulnerabilities: smart cameras, thermostats, and so on often have default passwords, no updates, weak encryption, and little security design. Many were recruited into botnets such as Mirai.

Insider threats: malicious (revenge, theft) or accidental (clicking a bad link, misconfiguring something). They are dangerous because insiders are already trusted.

APT (Advanced Persistent Threat): a stealthy, long-term, well-resourced intrusion, usually by nation-states or organized groups. The goal is to stay hidden for months and steal data.

CHECK YOURSELF

1. What is the main difference between a virus and a worm?
2. A CEO receives a convincing email that mentions their recent trip, and it asks them to approve a wire transfer. Name the attack.
3. Someone follows an employee through a badge-secured door. What is this called?
4. Which attack primarily targets **availability**?
5. Why are IoT devices frequently compromised?

1.3 Explain access management principles

PLAIN-ENGLISH IDEA

It's the bouncer at the club door: *Who are you? What are you allowed to do? What did you do?*

DEEP DIVE

AAA:

- **Authentication:** prove who you are (password, fingerprint, token)
- **Authorization:** what you're allowed to do (permissions)
- **Accounting:** logging what you did (audit trail)

RADIUS (Remote Authentication Dial-In User Service): a **centralized** AAA protocol. Network devices (Wi-Fi access points, VPNs, switches) ask a RADIUS server to verify users. It uses **UDP** (ports **1812/1813**, older **1645/1646**). It encrypts only the password in the packet. (**TACACS+** is Cisco's alternative: it uses TCP port 49 and encrypts the whole payload. It's worth knowing it exists.)

MFA (Multifactor Authentication): combines factors from **different categories**:

Factor	Example
Something you **know**	Password, PIN
Something you **have**	Phone, smart card, hardware token
Something you **are**	Fingerprint, face
Somewhere you are / something you do	Location, behavior (less common)

> Two passwords is **not** MFA, because both are the same factor type.

Password policies: minimum length (longer is stronger; many frameworks favor 12+ characters), complexity, no reuse, lockout after repeated failures, expiry (modern guidance such as NIST favors changing passwords only when compromise is suspected), and use of password managers and passphrases.

CHECK YOURSELF

1. Match each term to its question: Authentication, Authorization, Accounting → "Who are you?", "What can you do?", "What did you do?"
2. A bank asks for your password and a code sent to your phone. Which two factor types are used?
3. Is a password plus a security question true MFA? Why or why not?
4. Which transport protocol does RADIUS use?

1.4 Explain encryption methods and applications

PLAIN-ENGLISH IDEA

Encryption scrambles data so only someone with the right key can read it.

DEEP DIVE

Types of encryption:

	Symmetric	Asymmetric
Keys	**One shared** key	**Pair**: public + private
Speed	Fast	Slower
Use	Bulk data	Key exchange, digital signatures
Examples	**AES**, 3DES	**RSA**, ECC

- Public key encrypts → only the private key decrypts (confidentiality).
- Private key **signs** → anyone with the public key verifies (integrity and authenticity).

Hashing is **one-way**, with no key. Output is a fixed-length "fingerprint," and any change in the input changes the hash completely. It's used for **integrity** and password storage. Examples: **SHA-256** (strong), **MD5** and **SHA-1** (weak, collisions found). Hashing is **not** encryption, because you can't reverse it.

Certificates and PKI: A **digital certificate** binds a public key to an identity (such as a website). A **Certificate Authority (CA)** signs it to vouch for it. **PKI** is the whole system: CAs, registration authorities, certificates, revocation lists (CRL/OCSP), and key management. Your browser trusts a site because its certificate chains back to a trusted root CA.

Strong vs. weak algorithms:

Strong	Weak / deprecated
AES-128/256, RSA 2048+, SHA-256+, ECC	DES, 3DES (retiring), RC4, MD5, SHA-1, WEP

States of data:

State	Meaning	Protect with
At rest	Stored on disk	Full-disk encryption (BitLocker, FileVault), database encryption
In transit	Moving across a network	TLS/HTTPS, VPN (IPsec), SSH
In use	Being processed in memory	Hard to protect; secure enclaves, access controls

Protocols that use encryption: HTTPS (HTTP over TLS), **SSH** (secure remote login, replaces Telnet), **SFTP/FTPS** (secure file transfer), **IPsec** and **SSL/TLS VPNs**, **WPA2/WPA3** (Wi-Fi), **SMTPS/IMAPS/POP3S**, and **DNSSEC** (signs DNS records; strictly it provides authenticity, not secrecy).

CHECK YOURSELF

1. Why is hashing not the same as encryption?
2. Which key do you use to verify a digital signature?
3. Which is stronger for the exam: MD5 or SHA-256?
4. A laptop is stolen. Which kind of encryption protects the data on its drive?
5. Telnet vs. SSH: which one is secure, and why?

Domain 1 Answer Key

1.1: (1) B. (2) Exploit. (3) Integrity. (4) If one layer fails, the others still protect you. A single control is a single point of failure. (5) White hat (ethical hacker).

1.2: (1) A virus needs a host file and user action. A worm self-replicates over networks. (2) Spear phishing (or whaling, since the target is an executive). (3) Tailgating. (4) Denial of Service (DoS/DDoS). (5) Default or weak passwords, no patches, weak security design.

1.3: (1) Authentication = who are you; authorization = what can you do; accounting = what did you do. (2) Something you know and something you have. (3) No. Both are "something you know," so the factors aren't different categories. (4) UDP.

1.4: (1) Hashing is one-way and keyless; encryption is reversible with a key. (2) The signer's public key. (3) SHA-256. (4) Encryption at rest (full-disk encryption). (5) SSH, because it encrypts traffic; Telnet sends everything in plaintext.

DOMAIN 2: Basic Network Security Concepts

2.1 Describe TCP/IP protocol vulnerabilities

PLAIN-ENGLISH IDEA

Many internet protocols were designed in the 1970s–80s, when everyone on the network was trusted. So they have weak spots.

DEEP DIVE

Protocol	What it does	Weakness / attack
TCP	Reliable, connection-oriented (3-way handshake: SYN, SYN-ACK, ACK)	**SYN flood** (half-open connections exhaust the server), session hijacking
UDP	Fast, connectionless, no handshake	**UDP flood**, easy to spoof the source, used in amplification DDoS
HTTP	Web traffic (port 80), **plaintext**	Sniffing, MitM, session hijacking → use **HTTPS (443)**
ARP	Maps IP → MAC on a LAN	**ARP spoofing/poisoning**: attacker sends fake replies so traffic goes through them (MitM). No authentication
ICMP	Diagnostics (ping, traceroute)	**Ping flood**, **Smurf attack**, ICMP tunneling, reconnaissance
DHCP	Auto-assigns IP addresses	**Rogue DHCP server** (hands out an attacker's gateway or DNS), **DHCP starvation**
DNS	Name → IP	**DNS spoofing/cache poisoning**, **DNS tunneling**, DNS amplification DDoS

Common defenses are DHCP snooping, Dynamic ARP Inspection, HTTPS, DNSSEC, rate limiting, and firewalls.

CHECK YOURSELF

1. Describe the three steps of the TCP handshake.
2. Which attack exploits ARP's lack of authentication?
3. Why is HTTP risky for logging in?
4. What is a rogue DHCP server and why is it dangerous?
5. Which protocol is connectionless: TCP or UDP?

2.2 Explain how network addresses impact network security

PLAIN-ENGLISH IDEA

Every device needs an address, like a home address and a fingerprint. How you organize those addresses affects who can reach what.

DEEP DIVE

IPv4: 32 bits, written as four decimal octets (e.g., `192.168.1.10`).

IPv6: 128 bits, written in hexadecimal (e.g., `2001:db8::1`). It has a huge address space and built-in IPsec support, but you must secure it too (many networks run it unmonitored).

Private (RFC 1918) ranges:

- `10.0.0.0/8`
- `172.16.0.0/12` (172.16.0.0 to 172.31.255.255)
- `192.168.0.0/16`

Private addresses aren't routable on the internet. Anything else is **public**.

MAC address: a 48-bit hardware address (e.g., `00:1A:2B:3C:4D:5E`) used at Layer 2 on the local network. It can be **spoofed**, so it shouldn't be treated as strong identity.

Network segmentation: splitting a network into smaller parts (VLANs, subnets) to **limit lateral movement**, contain breaches, and enforce different rules per zone (e.g., guests, staff, servers, IoT).

CIDR notation: `address/prefix-length`. For example, `192.168.1.0/24` means the first 24 bits are the network portion, which gives 256 addresses (254 usable hosts). Quick math: **usable hosts = 2^(32 − prefix) − 2**.

- /24 → 254 hosts
- /30 → 2 hosts
- /16 → 65,534 hosts

NAT (Network Address Translation): translates private addresses to a public one at the edge. It conserves IPv4 addresses and hides internal addressing. **PAT** (NAT overload) lets many devices share one public IP using port numbers. NAT is *not* a firewall, though it does block unsolicited inbound connections by default.

Public vs. private networks: public networks (café Wi-Fi, the internet) are untrusted. Private ones (your LAN) are more controlled, but still need protection.

CHECK YOURSELF

1. Which of these is NOT a private address: 10.4.5.6, 172.20.1.1, 172.32.1.1, 192.168.50.2?
2. How many usable hosts are in a /26? (Hint: 2^6 − 2.)
3. Give two security benefits of network segmentation.
4. How many bits are in an IPv6 address?
5. Can you fully trust a MAC address as proof of identity? Why?

2.3 Describe network infrastructure and technologies

PLAIN-ENGLISH IDEA

These are the building blocks and gadgets that make a network safer.

DEEP DIVE

- **Network security architecture:** designing zones and controls (perimeter firewall, internal segmentation, secure remote access, monitoring). Modern thinking includes **Zero Trust** ("never trust, always verify").
- **DMZ (Demilitarized Zone):** a buffer network between the internet and the internal LAN that hosts **public-facing servers** (web, mail). If a DMZ server is compromised, the attacker still faces another firewall before reaching internal systems.
- **Virtualization:** one physical machine runs many virtual machines (VMs). It provides isolation and easy snapshots, but a **hypervisor** compromise or **VM escape** is dangerous, and VM sprawl is hard to manage.

- **Cloud:** services run on a provider's infrastructure (IaaS, PaaS, SaaS). It follows a **shared responsibility model**: the provider secures the cloud itself, and you secure what you put in it (configuration, data, access). Misconfiguration is a top cause of breaches.
- **Honeypot:** a **decoy** system built to attract attackers so you can study their techniques and detect them early. A **honeynet** is a network of honeypots.
- **Proxy server:** an intermediary for client requests. It provides content filtering, caching, anonymity, and logging. A **reverse proxy** sits in front of servers to protect and load-balance them.
- **IDS (Intrusion Detection System): monitors and alerts**. It is passive and often out-of-band, watching a copy of the traffic.
- **IPS (Intrusion Prevention System):** sits **inline** and can **block** malicious traffic.
- Detection methods: **signature-based** (known patterns, with fast, accurate detection of known threats but blind to new ones) and **anomaly-based** (deviations from a baseline, which can find new threats but has more false positives).

> Exam trick: IDS = **D**etect/alert. IPS = **P**revent/block.

CHECK YOURSELF

1. What is the purpose of a DMZ?
2. Difference between IDS and IPS?
3. In cloud computing, who is responsible for securing customer data?
4. What is a honeypot used for?
5. Which IDS detection method catches brand-new, unknown attacks better?

2.4 Set up a secure wireless SoHo network

PLAIN-ENGLISH IDEA

Home and small-office Wi-Fi is often the weakest link. Here is how to lock it down.

DEEP DIVE

Encryption standards (best to worst):

Standard	Status
WPA3	Best. Uses SAE (stronger handshake, protects against offline password guessing)
WPA2 (AES/CCMP)	Good, widely used
WPA (TKIP)	Outdated
WEP	**Broken**, crackable in minutes. Never use
Open (no encryption)	Anyone can sniff traffic

Secure setup checklist:

1. Change the router's **default admin username and password**.
2. Enable **WPA3** (or WPA2-AES) with a long, unique passphrase.
3. **Change the default SSID** (the network name), and avoid names that reveal your identity or router model.
4. Update router **firmware**.
5. Disable **WPS** (it has known weaknesses).
6. Disable remote administration unless needed.

7. Use a separate **guest network** (and put IoT devices on it).
8. Enable the router's firewall.

MAC address filtering: allows only listed MAC addresses. It's a minor deterrent only, because MACs are visible over the air and can be **spoofed**. Don't rely on it.

SSID hiding: disabling SSID broadcast only hides the name from casual users. It is **not** real security, because attackers can still find it.

CHECK YOURSELF

1. Which Wi-Fi encryption standard should you NEVER use?
2. Why is MAC filtering weak security?
3. Name three steps to secure a new home router.
4. Is hiding the SSID a real security measure?
5. Why use a guest network?

2.5 Implement secure access technologies

PLAIN-ENGLISH IDEA

These tools decide who gets in, from where, and under what conditions.

DEEP DIVE

- **ACL (Access Control List):** an ordered list of **permit/deny** rules applied to routers, switches, or firewalls. Rules are checked **top-down**, and the **first match wins**. There is an **implicit "deny all"** at the end. Rules match on source/destination IP, protocol, and ports.
- **Firewall:** controls traffic between networks based on rules.
  - **Packet filtering:** checks headers (IP/port) with no memory of connections.
  - **Stateful:** tracks connection state, so return traffic of an allowed session is automatically permitted.
  - **Application/proxy and NGFW (Next-Gen):** inspect application content, users, and threats.
  - **Host-based vs. network-based** firewalls.
- **VPN (Virtual Private Network):** an encrypted tunnel over an untrusted network.
  - **Remote-access VPN:** a single user connects to the company network.
  - **Site-to-site VPN:** connects two networks.
  - Technologies: **IPsec**, **SSL/TLS** VPN. It provides confidentiality, integrity, and authentication.
- **NAC (Network Access Control):** checks a device (identity, patch level, antivirus status) **before** letting it onto the network. Non-compliant devices can be blocked or quarantined. Example: Cisco ISE.

CHECK YOURSELF

1. Where does an ACL stop reading once a rule matches?
2. What is the final, hidden rule in most ACLs?
3. Stateful vs. stateless firewall: what's the difference?
4. A remote employee needs to safely reach the company network from a hotel. Which technology?
5. What does NAC do when a laptop has no antivirus?

Domain 2 Answer Key

2.1: (1) SYN → SYN-ACK → ACK. (2) ARP spoofing/poisoning. (3) It's plaintext, so credentials can be sniffed. (4) An unauthorized DHCP server that gives clients a malicious gateway or DNS, enabling MitM. (5) UDP.

2.2: (1) 172.32.1.1 (the private range ends at 172.31.255.255). (2) 62. (3) Limits lateral movement; contains breaches; allows tailored rules per zone. (4) 128. (5) No, it can be spoofed.

2.3: (1) Hosts public-facing servers in a buffer zone, protecting the internal LAN. (2) IDS detects and alerts; IPS sits inline and blocks. (3) The customer (shared responsibility). (4) To lure and study attackers and detect intrusions. (5) Anomaly-based.

2.4: (1) WEP. (2) MACs can be seen and spoofed. (3) Any three: change default credentials, WPA3/WPA2-AES, new SSID, update firmware, disable WPS, guest network. (4) No. (5) Isolates visitors/IoT from your main devices.

2.5: (1) At the first match. (2) Implicit deny. (3) Stateful tracks connection state; stateless looks at each packet in isolation. (4) VPN. (5) Blocks or quarantines it until it's compliant.

DOMAIN 3: Endpoint Security Concepts

3.1 Describe operating system security concepts

PLAIN-ENGLISH IDEA

Your computer's operating system is the front line. Knowing its built-in protections is half the battle.

DEEP DIVE

Windows, macOS, Linux (security overview):

OS	Key security features
Windows	**Windows Defender** (antivirus, now Microsoft Defender), **Windows Firewall**, **BitLocker**, UAC (User Account Control), Windows Update
macOS	**Gatekeeper** (checks app signing), **XProtect**, **FileVault** (disk encryption), SIP (System Integrity Protection), firewall
Linux	Strong permissions model, **sudo**, SELinux/AppArmor, `iptables`/`nftables`/`ufw` firewalls, package-manager updates

Host-based firewalls: software firewalls on each device. They provide protection even when the device is outside the corporate network.

CLI and PowerShell: the command line lets admins check and change security settings quickly and script tasks. PowerShell is Windows' powerful, object-based shell (e.g., `Get-Process`, `Get-LocalUser`, `Get-EventLog`). Linux uses Bash.

File and directory permissions:

- **Linux:** read (**r=4**), write (**w=2**), execute (**x=1**) for **owner / group / others**. Example: `chmod 750 file` → owner rwx, group r-x, others none. Use `ls -l` to view.
- **Windows (NTFS):** permissions like Read, Write, Modify, Full Control, assigned to users and groups via ACLs.
- Follow the **principle of least privilege**: give only the access needed.

Privilege escalation: gaining higher access than intended.

- **Vertical:** regular user → admin/root.
- **Horizontal:** one user → another user's resources at the same level.

Common causes are unpatched vulnerabilities, misconfigured permissions, and weak credentials. Prevent with least privilege, patching, and monitoring.

CHECK YOURSELF

1. What does `chmod 640` give the owner, group, and others?
2. What is vertical privilege escalation?
3. Which macOS feature encrypts the disk? Which Windows feature?
4. Why run a host-based firewall even inside a corporate network?
5. Define the principle of least privilege.

3.2 Demonstrate familiarity with endpoint tools

PLAIN-ENGLISH IDEA

These command-line tools are like a doctor's stethoscope for your computer's network activity.

DEEP DIVE

`netstat`**:** shows network connections, listening ports, and routing information.

- `netstat -a` → all connections and listening ports
- `netstat -n` → numeric addresses (no name lookup)
- `netstat -b` → shows the program (Windows, needs admin)
- `netstat -o` → shows process IDs (Windows)
- Common combo: `netstat -ano` (Windows).

Use it to spot **unexpected listening ports** or **suspicious outbound connections** (possible malware calling home).

`nslookup`**:** queries DNS to resolve names to IPs (or reverse).

- `nslookup example.com` → returns the IP
- Use it to check DNS records and to spot **suspicious or spoofed** DNS responses.

`tcpdump`**:** a command-line **packet capture** tool (Linux/macOS).

- `tcpdump -i eth0` → capture on an interface
- `tcpdump port 80` → filter by port
- `tcpdump host 192.168.1.5` → filter by host
- `tcpdump -w capture.pcap` → save to a file you can open in Wireshark.

Packet captures reveal exactly what is on the wire (and prove why plaintext protocols are dangerous). **Only capture traffic on networks you're authorized to monitor.**

CHECK YOURSELF

1. Which tool lists open ports and active connections?
2. Which tool would you use to capture raw packets?
3. What does `nslookup` do?
4. You see an unknown program connected to a foreign IP on port 4444. Which tool revealed it, and what's your concern?
5. Which `tcpdump` option saves output to a file?

3.3 Verify that endpoint systems meet security policies and standards

PLAIN-ENGLISH IDEA

You can't protect what you don't know you have. And every device must follow the rules.

DEEP DIVE

- **Hardware inventory (asset management):** a list of every device (laptops, servers, phones), who owns it, and where it is. This finds unauthorized and forgotten devices.
- **Software inventory:** every application and version installed. It helps find unapproved or vulnerable software.
- **Program deployment:** pushing software and updates centrally (e.g., Intune, SCCM, Jamf) so every device is consistent.
- **Data backups:** regular, tested copies. Follow the **3-2-1 rule**: **3** copies, **2** media types, **1** offsite. Offline or immutable backups beat ransomware.

- **Regulatory compliance:**

Law/Standard	Protects
PCI DSS	Payment card data
HIPAA	Health information (US)
GDPR	Personal data of people in the EU

- **BYOD (Bring Your Own Device):** personal devices used for work. Risks: mixed data, unmanaged devices, lost phones. Controls:
  - **Device management (MDM/EMM)**
  - **Data encryption**
  - **App distribution** (approved apps only)
  - **Configuration management** (enforce passcodes, patches, and remote wipe)

CHECK YOURSELF

1. Which regulation covers credit card data?
2. State the 3-2-1 backup rule.
3. Why does a software inventory matter for security?
4. Name two controls for BYOD.
5. Which law protects health information in the US?

3.4 Implement software and hardware updates

PLAIN-ENGLISH IDEA

Most attacks use *known* flaws that already have a fix. Updating is like locking a door you know was left open.

DEEP DIVE

- **Windows Update:** delivers OS and security patches. Can be automatic or managed (WSUS, Intune).
- **Application updates:** browsers, Office, PDF readers, and so on. Attackers love outdated apps.
- **Device drivers:** software that lets the OS talk to hardware. Buggy or outdated drivers can be exploited.
- **Firmware:** low-level software on hardware (router, BIOS/UEFI, IoT). Often forgotten, so **routers and IoT** are easy targets.
- **Patching process** (good practice): inventory → **test** in a non-production environment → schedule → deploy → **verify** → document, with a **rollback plan** if something breaks.
- **Zero-day:** a vulnerability with **no patch yet**, so you use compensating controls (segmentation, monitoring, workarounds).

CHECK YOURSELF

1. Why should patches be tested before wide deployment?
2. What is a zero-day vulnerability?
3. Which is often neglected: OS updates or router firmware?
4. Name three types of updates the exam lists.

3.5 Interpret system logs

PLAIN-ENGLISH IDEA

Logs are your computer's diary. When something bad happens, the diary tells the story.

DEEP DIVE

- **Event Viewer (Windows):** the tool for viewing logs. Main logs: **Application**, **Security**, **System** (plus Setup and Forwarded Events).
- **Useful Windows Event IDs: 4624** (successful logon), **4625** (failed logon), **4720** (account created), **4672** (special privileges assigned), **1102** (audit log cleared, which is suspicious).
- **Audit logs:** record who did what and when (logons, file access, policy changes).
- **System and application logs:** OS events (startups, crashes, driver errors) and software-specific events.
- **Syslog:** the standard for sending logs from devices to a **central server** (UDP 514 by default). Messages have **severity levels 0–7**: 0 Emergency, 1 Alert, 2 Critical, 3 Error, 4 Warning, 5 Notice, 6 Info, 7 Debug. Lower is more severe.
- **Identifying anomalies:** look for many failed logins followed by a success (brute force), logins at odd hours or from unusual places, new accounts or privilege changes, logs being cleared, unusual spikes in traffic, and unknown processes.

Always send logs to a **central, protected** location so attackers can't erase their tracks.

CHECK YOURSELF

1. Which Windows tool shows logs?
2. 50 failed logins followed by one success from the same IP. What might it indicate?
3. Why centralize logs with syslog?
4. Which syslog severity is more serious: 2 or 6?
5. Why is "audit log cleared" a red flag?

3.6 Demonstrate familiarity with malware removal

PLAIN-ENGLISH IDEA

If a device is infected, there is a careful procedure to clean it, and you can't just delete one file and hope.

DEEP DIVE

Typical steps (recognized best-practice order):

1. **Identify** symptoms (slow system, pop-ups, unknown processes, disabled antivirus).
2. **Quarantine/isolate** the machine (disconnect from the network) to stop spread.
3. **Disable System Restore** where relevant (malware can hide in restore points).
4. **Remediate:** update the antivirus signatures, **scan** (full scan, or an offline/boot-time scan for stubborn threats), and remove or quarantine detections.
5. **Review scan logs:** which files were detected, what was removed, and what could not be cleaned.
6. **Re-enable and verify:** re-scan, confirm the system works, and monitor.
7. **Restore from a clean backup** if the system can't be trusted (e.g., rootkits, ransomware).
8. **Educate** the user and **document** what happened. Find the **root cause** so it doesn't recur.

> If malware is suspected on critical systems, escalate to the incident response process (Domain 5).

CHECK YOURSELF

1. What is the first containment step for an infected computer?
2. Why review scan logs?
3. When might you rebuild or restore from backup instead of cleaning?
4. Why update antivirus signatures before scanning?

Domain 3 Answer Key

3.1: (1) Owner read+write; group read; others none. (2) Gaining higher privileges (user → admin/root). (3) macOS: FileVault; Windows: BitLocker. (4) It protects each device even if the perimeter fails or the device leaves the network. (5) Give users only the minimum access needed.

3.2: (1) netstat. (2) tcpdump (or Wireshark). (3) Resolves DNS names to IPs and vice versa. (4) netstat; possible malware/backdoor connection. (5) `-w`.

3.3: (1) PCI DSS. (2) 3 copies, 2 different media, 1 offsite. (3) It reveals unapproved or vulnerable software. (4) Any two: MDM, encryption, approved app distribution, configuration management. (5) HIPAA.

3.4: (1) To avoid breaking systems; ensures compatibility. (2) A flaw with no available patch yet. (3) Router firmware. (4) Any three: Windows Update, application updates, device drivers, firmware.

3.5: (1) Event Viewer. (2) A brute-force or password-guessing attack that may have succeeded. (3) One protected place for analysis; attackers can't easily erase them. (4) 2 (Critical). (5) Attackers clear logs to hide their activity.

3.6: (1) Isolate from the network. (2) To see what was found, removed, or missed. (3) When the system is untrustworthy (rootkit, severe infection, ransomware). (4) So it can detect the latest threats.

DOMAIN 4: Vulnerability Assessment and Risk Management

4.1 Explain vulnerability management

PLAIN-ENGLISH IDEA

Finding and fixing weaknesses *before* attackers do. It's a cycle you repeat, not a one-time job.

DEEP DIVE

The vulnerability management cycle: identify (scan) → **assess/prioritize** (how severe? how exposed?) → **mitigate** (patch, configure, or compensate) → **verify** (re-scan) → **report and repeat**.

Mitigation options: patch, change configuration, add compensating controls (firewall rule, segmentation), or **accept** the risk (with approval).

Reconnaissance:

	Passive	Active
Interaction with target	**None** (doesn't touch it)	**Direct** (sends traffic)
Examples	Public records, WHOIS, social media, search engines, DNS records, OSINT	**Port scanning**, ping sweeps, banner grabbing
Detectable?	Hardly	Often yes (logs, IDS)

Testing:

- **Port scanning** (e.g., **Nmap**) finds open ports, services, and versions. Open ports show the attack surface.
- **Automation:** vulnerability scanners (Nessus, OpenVAS, Qualys) automatically scan and report known issues. They can produce **false positives** (reported but not real) and **false negatives** (missed real issues).
- **Vulnerability scan vs. penetration test:** a scan *finds* and lists weaknesses; a pen test *actively tries to exploit* them to prove impact.

> Only scan systems you **own or have written permission** to test.

CHECK YOURSELF

1. Put in order: Mitigate, Identify, Verify, Prioritize.
2. Is searching a company's public LinkedIn page active or passive recon?
3. What does a port scan reveal?
4. Difference between a vulnerability scan and a pen test?
5. What is a false positive?

4.2 Use threat intelligence techniques to identify potential network vulnerabilities

PLAIN-ENGLISH IDEA

Learn from what others have already discovered so you don't have to be hacked to find out.

DEEP DIVE

- **Vulnerability databases:**
  - **CVE (Common Vulnerabilities and Exposures):** a unique ID for each public vulnerability, in the format **CVE-YEAR-NUMBER** (e.g., CVE-2021-44228, Log4Shell). Run by MITRE (cve.org).
  - **NVD (National Vulnerability Database, nvd.nist.gov):** NIST's database that enriches CVEs with **CVSS severity scores** (0–10: Low, Medium, High, Critical).
  - **Uses:** know what to patch and how bad it is. **Limits:** may lag behind new discoveries, miss zero-days, and not reflect *your* environment's context.
- **Industry-standard tools:** vulnerability scanners (Nessus, OpenVAS, Qualys), Nmap, Wireshark, SIEMs. They produce **recommendations, policies, and reports** for decision-makers.
- **Sources of threat intelligence:** cybersecurity reports (e.g., Verizon DBIR), **news**, **subscription services** (paid feeds), and **collective intelligence** (communities sharing, e.g., ISACs, CISA alerts).
- **Ad hoc vs. automated intelligence:** *ad hoc* is manual, as-needed research; *automated* is feeds ingested directly into your security tools (e.g., into the SIEM/firewall).
- **Communication and documentation (important and often missed):** keep stakeholders informed **before** (preparation and training), **during** (status updates), and **after** (lessons learned) an incident. Documentation must be **secured** (access controls, encryption), **shared** with the right people only, and **kept up to date**.

CHECK YOURSELF

1. What does CVE stand for, and what does it give each vulnerability?
2. What scale does CVSS use?
3. Give one limitation of vulnerability databases.
4. Difference between ad hoc and automated threat intelligence?
5. Why must incident documentation be secured?

4.3 Explain risk management

PLAIN-ENGLISH IDEA

You can't fix everything. Risk management helps you decide what to fix first, what to insure, and what to live with.

DEEP DIVE

Vulnerability vs. risk: a vulnerability is a weakness. Risk is the *chance* that it is exploited **and** the *damage* if it is. A scary vulnerability on an isolated, unimportant machine can be **low** risk.

Ranking risks: combine **likelihood** × **impact**. Common levels: **Low, Medium, High, Extremely High**. Use a **risk matrix** (likelihood on one axis, impact on the other).

Four approaches to risk:

Approach	Meaning	Example
Avoid	Stop the risky activity	Don't store card numbers at all
Mitigate/Reduce	Add controls	Install a firewall, patch
Transfer/Share	Move the risk to others	Cyber insurance, outsourcing
Accept	Live with it (if the cost of fixing exceeds the risk)	Tolerating a minor issue

Data classification and risks: data is labeled by sensitivity (e.g., **Public, Internal, Confidential, Restricted/Secret**; government uses Top Secret, etc.). The more sensitive the data (PII, health data, financial data, trade secrets), the higher the potential impact of exposure, and the stronger the controls required.

Security assessments of IT systems: reviews across areas like **information security**, **change management** (controlled, documented changes that avoid accidental weaknesses), **computer operations**, and **information assurance** (overall confidence in data's confidentiality, integrity, and availability).

CHECK YOURSELF

1. What two factors combine to make risk?
2. Buying cyber insurance is which risk approach?
3. Name the four risk levels listed in the objectives.
4. Why can a critical vulnerability be low risk in some cases?
5. Why does data classification matter?

4.4 Explain the importance of disaster recovery and business continuity planning

PLAIN-ENGLISH IDEA

Bad things happen: fires, floods, ransomware. A plan means the business survives them.

DEEP DIVE

Disasters:

- **Natural:** floods, earthquakes, fires, hurricanes.
- **Human-caused:** cyberattacks, sabotage, human error, power failures, war or terrorism.

BCP (Business Continuity Plan): keeps the **whole business operating** during and after a disruption (alternate workflows, staff, locations, communication). It is broader.

DRP (Disaster Recovery Plan): focuses on **restoring IT systems and data** after a disaster. It is narrower and technical.

Key DRP features: an asset and risk inventory, defined roles and contacts, step-by-step recovery procedures, **backups**, alternate sites, **testing and drills**, and regular updates.

Useful targets:

- **RTO (Recovery Time Objective):** the maximum acceptable downtime.
- **RPO (Recovery Point Objective):** the maximum acceptable data loss, measured in time (e.g., 4 hours of data).

Backups: full, incremental (changes since the last backup of any kind), and differential (changes since the last full). Store copies offsite and **test restores**.

Alternate sites: hot (ready now), **warm** (partly ready), **cold** (empty space).

Disaster recovery controls:

Type	Purpose	Examples
Preventive	Stop the incident	Firewalls, backups, redundant power, training
Detective	Discover it	IDS, monitoring, alarms, log review
Corrective	Fix and restore after	Restoring from backup, patching, failover

CHECK YOURSELF

1. BCP vs. DRP: which is broader?
2. What does RTO measure?
3. Classify each: an IDS alert (D/P/C), restoring from backup (D/P/C), a fire-suppression system (D/P/C).
4. Why must you *test* backups?
5. Give one natural and one human-caused disaster.

Domain 4 Answer Key

4.1: (1) Identify → Prioritize → Mitigate → Verify. (2) Passive. (3) Open ports and services (attack surface). (4) A scan finds weaknesses; a pen test tries to exploit them. (5) A reported issue that isn't actually real.

4.2: (1) Common Vulnerabilities and Exposures; a unique ID. (2) 0–10. (3) Any one: lag, miss zero-days, lack of local context. (4) Ad hoc is manual and as needed; automated feeds in directly to tools. (5) It contains sensitive details that could help attackers or harm the organization.

4.3: (1) Likelihood and impact. (2) Transfer. (3) Low, Medium, High, Extremely High. (4) It may be isolated, hard to reach, or protect no valuable data. (5) It determines how strongly data should be protected.

4.4: (1) BCP. (2) Maximum acceptable downtime. (3) IDS = Detective; restore = Corrective; fire suppression = Preventive. (4) A backup that can't be restored is useless. (5) E.g., earthquake (natural); ransomware (human-caused).

DOMAIN 5: Incident Handling

5.1 Monitor security events and know when escalation is required

PLAIN-ENGLISH IDEA

Security teams watch for trouble all day. Your job is to spot suspicious events and know when to call for help.

DEEP DIVE

- **SIEM (Security Information and Event Management):** collects and **correlates** logs from many sources (firewalls, servers, endpoints) in one place, then **alerts** on suspicious patterns. Examples: Splunk, Microsoft Sentinel, IBM QRadar.
- **SOAR (Security Orchestration, Automation and Response): automates responses** using playbooks (e.g., auto-block an IP, disable an account, open a ticket).

> Simple split: **SIEM sees and alerts. SOAR acts.**

- **Monitoring network data:** packet captures (PCAP), NetFlow, firewall logs, DNS logs, IDS/IPS alerts, and endpoint logs.
- **Identifying suspicious events:** repeated failed logins, traffic to known-bad IPs, large data transfers at night, unusual new admin accounts, malware alerts, port scans, or services opening unexpectedly.
- **Escalation:** when you **can't resolve it at your level**, or when it involves **confirmed compromise**, **sensitive or regulated data**, **critical systems**, **spreading malware**, or **ongoing active attack**. Follow the documented procedure, and hand over with clear notes (what, when, where, evidence, actions taken).
- **False positives vs. true positives:** investigate before you escalate, but don't ignore alerts.

CHECK YOURSELF

1. What is the difference between SIEM and SOAR?
2. Name three data sources you'd monitor for incidents.
3. Give two situations that should be escalated.
4. Why does a SIEM correlate logs from many sources?

5.2 Explain digital forensics and attack attribution processes

PLAIN-ENGLISH IDEA

After an attack, you're a detective: collect clues carefully, understand how the attacker worked, and avoid ruining the evidence.

DEEP DIVE

Cyber Kill Chain (Lockheed Martin), 7 stages:

1. **Reconnaissance**
2. **Weaponization**
3. **Delivery**
4. **Exploitation**

5. **Installation**
6. **Command & Control (C2)**
7. **Actions on Objectives**

Defenders aim to **break the chain early** (the earlier, the cheaper).

MITRE ATT&CK Matrix: a public knowledge base of real-world attacker behaviors, organized by **Tactics** (the *why*, e.g., Initial Access, Persistence, Lateral Movement, Exfiltration) and **Techniques** (the *how*, each with an ID like T1566 Phishing). Used to map attacks, detect gaps, and speak a common language.

Diamond Model of Intrusion Analysis: every event has four connected parts: **Adversary, Capability, Infrastructure, Victim**. Analysts pivot among them to connect incidents.

TTPs (Tactics, Techniques, and Procedures): an adversary's behavioral "signature." *Tactics* = goals, *techniques* = methods, *procedures* = specific implementations. TTPs are valuable for attribution because they're harder for attackers to change than IP addresses.

Sources of evidence (artifacts): logs, memory (RAM) contents, disk images, network traffic captures, registry entries, email headers, browser history, running processes, and files.

Evidence handling:

- **Preserve** evidence: don't modify the original. Make a **forensic copy/image** and work on the copy, verifying with a **hash**.
- **Order of volatility:** collect the most volatile first (**RAM/cache → network state/processes → disk → backups/archives**), because it disappears first.
- **Chain of custody:** a documented record of **who** handled the evidence, **when**, **where**, and **why**, from collection to court. A broken chain can make evidence **inadmissible**.
- **Attribution** (who did it) is difficult and uncertain. It relies on TTPs, infrastructure, and malware similarities, and attackers can fake or reuse clues.

CHECK YOURSELF

1. Name the first and last stages of the Cyber Kill Chain.
2. In MITRE ATT&CK, what is the difference between a tactic and a technique?
3. What are the four parts of the Diamond Model?
4. What is chain of custody and why does it matter?
5. Which evidence is most volatile: RAM or a hard disk?

5.3 Explain the impact of compliance frameworks on incident handling

PLAIN-ENGLISH IDEA

Some laws require you to follow certain steps and tell certain people after a breach.

DEEP DIVE

Framework	Scope	Why it matters in incidents
GDPR	Personal data of EU residents (any company worldwide handling it)	Breach notification to the supervisory authority generally **within 72 hours** of becoming aware, and to affected individuals when risk is high; large fines
HIPAA	US health information (PHI)	**Breach Notification Rule**: notify affected individuals, HHS, and sometimes the media

Framework	Scope	Why it matters in incidents
PCI DSS	Cardholder data	Requires incident response plans; breaches must be reported to the card brands/acquirer
FERPA	US student education records	Restricts disclosure of student records
FISMA	US federal agencies' information systems	Requires security programs and incident reporting (to CISA/US-CERT)

Impact on handling: compliance dictates **what you must report, to whom, and how fast**; how you **preserve evidence and document**; and who must be involved (legal, privacy officers, executives). It also changes the penalties for failures.

> Always check your *current* local rules, since notification periods and details vary by region and can change.

CHECK YOURSELF

1. Which framework generally has a 72-hour notification rule?
2. Which framework covers student records?
3. Which covers payment card data?
4. Why involve legal/compliance teams during a breach?

5.4 Describe the elements of cybersecurity incident response

PLAIN-ENGLISH IDEA

A fire drill for cyberattacks. You have a step-by-step playbook so people don't panic.

DEEP DIVE

Policy, plan, and procedure elements:

- **Policy:** high-level management statement (authority, scope, roles, definitions of an "incident," reporting duties).
- **Plan:** how the organization will respond (team structure, roles, communication, resources, metrics, executive approval).
- **Procedures:** detailed step-by-step instructions (playbooks and checklists) for specific incident types, such as ransomware or phishing.
- **The CSIRT/IR team:** incident manager, analysts, IT, legal, HR, PR, and management.

NIST SP 800-61 incident response lifecycle (the exam cites sections 2.3 and 3.1–3.4 of the revision it uses; the classic Rev. 2 model has four phases):

1. **Preparation:** policies, tools, training, communication plans, and hardening systems, *before* anything happens.
2. **Detection & Analysis:** identify and validate incidents, determine scope and severity, document, prioritize, and notify.
3. **Containment, Eradication & Recovery:**
   - **Containment:** stop the spread (isolate hosts, block IPs). Short-term versus long-term strategies.
   - **Eradication:** remove the cause (delete malware, close the vulnerability, disable compromised accounts).
   - **Recovery:** restore systems to normal, validate, and monitor.
4. **Post-Incident Activity:** the **lessons learned** meeting, reports, evidence retention, and improvement of the plan.

Memory aid: **P**repare → **D**etect/Analyze → **C**ontain/Eradicate/Recover → **P**ost-incident review. It's a **cycle**: lessons learned feed back into preparation.

Note: NIST published a newer revision (Rev. 3) in 2025 that reorganizes the model, aligning it with the NIST Cybersecurity Framework. Since your objectives cite specific section numbers, study the version Cisco's materials use, and confirm which revision they reference on Cisco's exam page.

CHECK YOURSELF

1. List the four NIST incident response phases in order.
2. Difference between containment and eradication?
3. When does "lessons learned" happen, and why?
4. Which phase includes training and tool setup?
5. Difference between a policy and a procedure?

Domain 5 Answer Key

5.1: (1) SIEM collects, correlates, and alerts; SOAR automates response. (2) Any three: firewall logs, endpoint logs, PCAP, DNS logs, IDS alerts, NetFlow. (3) Any two: confirmed compromise, regulated data, critical systems, spreading malware, an attack beyond your authority. (4) It connects events that look harmless alone into a recognizable attack pattern.

5.2: (1) Reconnaissance; Actions on Objectives. (2) A tactic is the goal (why); a technique is the method (how). (3) Adversary, Capability, Infrastructure, Victim. (4) A documented record of who handled evidence, when, and why; it keeps evidence admissible and trustworthy. (5) RAM.

5.3: (1) GDPR. (2) FERPA. (3) PCI DSS. (4) They guide notification duties, deadlines, and legal risk.

5.4: (1) Preparation → Detection & Analysis → Containment, Eradication & Recovery → Post-Incident Activity. (2) Containment stops the spread; eradication removes the root cause. (3) After the incident; to improve future response. (4) Preparation. (5) A policy is high-level direction; a procedure is detailed step-by-step instructions.

Final Study Plan and Exam Tips

A 6-week plan (adjust to your date):

Week	Focus
1	Domain 1: memorize the vocabulary with flashcards
2	Domain 2: practice CIDR math and ACL reading; build a lab in Packet Tracer
3	Domain 3: practice `netstat`, `nslookup`, `tcpdump`, and Linux permissions in a VM
4	Domain 4: browse the NVD, read a CVE, and run a legal Nmap scan of your own lab
5	Domain 5: map a real attack story to the Kill Chain and ATT&CK
6	Mixed practice questions, then redo everything you got wrong

Hands-on labs to do (free and legal):

- Capture traffic with Wireshark on your own network and observe HTTP vs. HTTPS.
- Secure a home Wi-Fi router using the checklist in 2.4.
- Look up a CVE on nvd.nist.gov and read its CVSS score.
- Explore attack.mitre.org and read one technique page.
- Read the real Windows Event Viewer **Security** log on your own PC.

Exam tips:

- Learn the **differences** (IDS vs. IPS, virus vs. worm, SIEM vs. SOAR, DRP vs. BCP). Many questions test exactly these pairs.
- Read each question for the *best* answer, not just a true one.
- Know your **ports**: HTTP 80, HTTPS 443, SSH 22, Telnet 23, DNS 53, RADIUS 1812/1813, Syslog 514.
- Practice a few CIDR calculations until they're automatic.
- Check the official Cisco exam page for the current exam format, length, and policies before test day, since these can change.